

Network controls: security groups, NACLs and the firewalls

Four controls that all look like filtering, operating at four different layers.

Four filters, four layers. **Identity, subnet, packet, name.**

Security group and network ACL

	SECURITY GROUP	NETWORK ACL
Attaches to	An ENI – so an instance	A subnet – so everything in it
State	Stateful; return traffic is automatic	Stateless; you must allow the return path
Rules	Allow only. No deny exists	Allow and deny, evaluated in number order
Evaluation	All rules; any allow permits	First match wins, lowest number first
References	Other security groups and prefix lists	CIDR blocks only
Default	Deny all inbound, allow all outbound	Default NACL allows everything both ways

ON THE EXAM

Two rows decide most questions: security groups cannot deny, and NACLs cannot reference a security group.

Security groups: the identity firewall

- ◆ **Reference another security group instead of a CIDR.** The rule survives every instance replacement.
- ◆ It is the closest AWS gets to identity-based networking.
- ◆ **Prefix lists** hold a named set of ranges – yours, or AWS-managed ones.
- ◆ **The default security group allows all traffic between members**, quietly flattening the network.
- ◆ **You cannot deny.** 'Block this specific address' is not expressible.

ON THE EXAM

Referencing answers almost every 'without hardcoding IPs as we scale' requirement.

Network ACLs: the blunt instrument

- ◆ **The only VPC control with explicit deny.** One job nothing else does.
- ◆ Lowest number first, first match wins – so a low-numbered deny beats every allow below.
- ◆ **Stateless.** Forget the ephemeral outbound range and the response never returns.
- ◆ **Subnet-wide.** Isolating one instance isolates every neighbour, as module 10 showed.
- ◆ Firewall Manager can enforce baseline **first and last NACL rules** org-wide.

ON THE EXAM

Use a NACL when you need deny, or something instance owners cannot override.

AWS Network Firewall: the parts

- ◆ A **firewall** deploys **endpoints per Availability Zone**. You route traffic to them; it is not transparent.
- ◆ A **firewall policy** references **stateless** and **stateful rule groups**, and sets default actions.
- ◆ **Stateless rules** match the 5-tuple in priority order: pass, drop, or forward to stateful.
- ◆ **Stateful rules** are **Suricata-compatible**, so standard IPS signatures work.
- ◆ Stateful order is **default action order** or **strict order**. Strict order is easier to reason about.

ON THE EXAM

If your route tables do not send traffic through the endpoints, it inspects nothing.

Network Firewall: deployment and TLS

- ◆ **Distributed** – a firewall per VPC. Simple, and you pay per firewall.
- ◆ **Centralised** – one inspection VPC behind a Transit Gateway.
- ◆ Firewall Manager deploys either model org-wide.
- ◆ **TLS inspection** decrypts, inspects and re-encrypts using an ACM certificate.
- ◆ TLS inspection is a privacy and compliance decision, not just a setting.

ON THE EXAM

Domain filtering works without decryption – it reads the SNI. Payloads need TLS inspection.

DNS Firewall: filtering the name

- ◆ Filters DNS queries leaving your VPC via the Route 53 Resolver. Rules evaluate in **priority order**.
- ◆ Actions **ALLOW, BLOCK, ALERT**. Block responses: NODATA, NXDOMAIN, or an override.
- ◆ **Foundational tier** uses domain lists – your own, or AWS-managed malware and botnet lists.
- ◆ Inspect **the whole redirection chain**, so a CNAME cannot smuggle you past a block.
- ◆ Filter by **query type** – allow MX through while blocking the rest.

ON THE EXAM

A strict allow list is a walled garden: only names you approved can resolve.

DNS Firewall Advanced, and the honest limit

- ◆ **Advanced tier, November 2024:** algorithmic detection of **DNS tunneling**, **DGAs** and **dictionary DGAs**.
- ◆ Inspects timing, frequency, query strings and payload sizes – catching domains no feed has seen.
- ◆ A rule holds **either a domain list or an Advanced protection**, never both. Advanced needs a **confidence threshold**.
- ◆ May 2026 added threat and content domain categories to the Advanced tier.
- ◆ **It filters names only.** Not HTTPS, SSH, TLS or FTP. A hardcoded IP walks past.

ON THE EXAM

DNS Firewall stops the lookup. Network Firewall stops the connection.

Seeing what the network did

- ◆ **VPC Flow Logs** – per ENI, subnet or VPC. Mind the ACCEPT/REJECT/ALL filter from module 6.
- ◆ **Transit Gateway Flow Logs** – named in skill 1.2.6, for traffic crossing a Transit Gateway.
- ◆ **Network Firewall alert and flow logs.** Alert logs name the rule that fired.
- ◆ **Route 53 Resolver query logs** – every name your VPC asked for.
- ◆ Flow logs carry metadata, never payload.

ON THE EXAM

Four log sources, four layers. A gap in one is invisible in the others.

Threat intelligence identifies a specific /24 address range that is scanning a company's public subnets. The company must block all traffic from that range to every instance in the affected subnet immediately, regardless of what each instance's security group permits. The subnet contains 40 instances owned by six different teams, each managing its own security groups.

What should the security team use?

- ☐ A Add a deny rule for the range to every security group in the subnet
- ☐ B Create a prefix list containing the range and reference it in the security groups
- ☐ C Add a low-numbered DENY rule for the range to the subnet's network ACL
- ☐ D Add the range to a DNS Firewall rule group associated with the VPC

◆ PAUSE AND DECIDE

What should the security team use?

A Deny rules in every security group

Security groups have no deny. There is no such rule to add, and it would need six teams to act anyway.

C Low-numbered DENY rule on the subnet's NACL

Correct. The NACL is the only VPC control with explicit deny, it applies subnet-wide regardless of security groups, and one change covers all 40 instances.

B Prefix list referenced in the security groups

A prefix list is just a named set of ranges. Referencing it still produces an allow rule, and it needs every team to change their groups.

D DNS Firewall rule group

DNS Firewall filters domain names, not IP addresses. A scanner connecting to an address never makes a DNS query you could block.

THE SIGNAL

'Regardless of what each security group permits' names the layer. Only a subnet-level control overrides instance-level ones.

A pharmaceutical company runs analysis workloads in private subnets. They must reach exactly three approved external HTTPS endpoints for licence checks and nothing else. Auditors require evidence that traffic to any other destination was blocked, not merely unresolved.

The team has already deployed DNS Firewall with a strict allow list. During a penetration test, a payload using a hardcoded IP address successfully exfiltrated data over HTTPS.

What should the company add?

- ☐ A AWS Network Firewall with a stateful domain list rule group, routing egress through the firewall endpoints
- ☐ B A network ACL denying all outbound traffic except to the three endpoints' current IP addresses
- ☐ C DNS Firewall Advanced rules for DNS tunneling and DGA detection
- ☐ D Security groups on the analysis instances allowing outbound 443 to the three domains

◆ PAUSE AND DECIDE

What should the company add?

A Network Firewall with a stateful domain list rule group

Correct. It inspects the actual connection and reads the SNI, so it blocks a hardcoded IP too - and its alert logs are the evidence the auditors want.

C DNS Firewall Advanced for tunneling and DGA
Valuable, and it is more DNS filtering. The exfiltration never made a DNS query, so no DNS-layer control could have seen it.

B NACL denying all but the three endpoints' IPs
It works until those endpoints change address, which SaaS endpoints do constantly. You would be maintaining an IP list against a moving target.

D Security groups allowing 443 to three domains
Security groups do not understand domains. They take CIDR blocks, prefix lists and other security groups - never a hostname.

THE SIGNAL

'A hardcoded IP address' is the scenario telling you the DNS layer was bypassed. Move down a layer, not sideways.

A bank's SOC notices unusual outbound DNS volume from a subnet: thousands of queries a minute for long, randomised subdomains of a domain registered three days ago. None of the domains appear on any AWS managed domain list or commercial threat feed.

The team wants to detect and block this pattern generally, not just this one domain, and would rather alert first than break a legitimate application.

What should the bank configure?

- ☐ A A DNS Firewall rule blocking the registered domain and its subdomains
- ☐ B A Network Firewall stateful rule dropping UDP port 53 from that subnet
- ☐ C GuardDuty Runtime Monitoring on the instances in that subnet
- ☐ D A DNS Firewall Advanced rule for DNS tunneling, with the ALERT action

◆ PAUSE AND DECIDE

What should the bank configure?

- A

 Block that domain and its subdomains
Stops today's incident and nothing else. The attacker registers another domain tomorrow, and you are back to chasing individual names.
- B

 Drop UDP 53 from that subnet
Breaks all name resolution for the subnet, which stops the workload as thoroughly as it stops the exfiltration.
- C

 GuardDuty Runtime Monitoring
Would likely reveal the process responsible, and it is investigation rather than a network control. It does not block the queries.
- D

 DNS Firewall Advanced tunneling rule, ALERT action
Correct. Advanced rules detect tunneling algorithmically from timing, frequency and query string patterns, so they catch domains no feed has seen. ALERT tests it safely.

THE SIGNAL

'Not on any threat feed' rules out every list-based control. Algorithmic detection is what remains.

A three-tier application runs behind an Auto Scaling group. The app tier's security group currently allows inbound 8080 from a list of the web tier's private IP addresses, maintained by a nightly script.

During a scaling event, new web instances receive addresses not yet in the list and their requests are refused until the script runs. The team wants this to stop happening.

What should the team change?

- ☐ A Widen the app tier rule to allow 8080 from the whole VPC CIDR
- ☐ B Allow inbound 8080 from the web tier's security group as the source
- ☐ C Move the web and app tiers into the default security group so they can talk freely
- ☐ D Replace the script with a network ACL allowing 8080 across the subnets

◆ PAUSE AND DECIDE

What should the team change?

- A

 Allow 8080 from the whole VPC CIDR
Fixes the symptom by removing the control. Every resource in the VPC, including a compromised one in an unrelated subnet, can now reach the app tier.
- B

 Source the rule from the web tier's security group
Correct. Membership rather than address, so a new instance is authorised the moment it joins the group. No script, no scaling gap.
- C

 Use the default security group
The default group allows all traffic between its members, which flattens the network entirely and removes the tier separation the design depends on.
- D

 NACL allowing 8080 across the subnets
NACLs take CIDR blocks only, so you are back to addresses - now applied subnet-wide and statelessly, which is strictly worse.

THE SIGNAL

A nightly script reconciling IP addresses is the tell. Security group referencing exists precisely to delete that script.

Five things to carry forward

- ◆ **Identity, subnet, packet, name.** Find the layer before reading the options.
- ◆ **Security groups cannot deny. NACLs cannot reference a security group.**
- ◆ **Reference the security group, not the addresses.** A script reconciling IPs is the tell.
- ◆ **DNS Firewall stops the lookup. Network Firewall stops the connection.**
- ◆ **DNS Firewall Advanced detects tunneling and DGAs algorithmically**, with no threat feed needed.

ON THE EXAM

Next: VPN, Direct Connect, MACsec, Transit Gateway and Verified Access.